

# NIST 800-30 Risk Assessment – WatchGuard System

## (Moderate Impact)

### OVERVIEW

This project expands on my previous NIST 800-37 Risk Management Framework (RMF) process for the WatchGuard moderate-impact information system operated by Winterfell Cyber Solutions. The goal of this project was to apply the NIST SP 800-30 risk assessment methodology to identify, analyze, and prioritize risks to the system’s confidentiality, integrity, and availability.

Using the results from the RMF authorization process, I conducted a detailed risk assessment to document threats, vulnerabilities, likelihoods, and impacts. The outcome includes a complete risk register, risk matrix, and formal risk assessment report aligned with federal risk management standards.

---

### OBJECTIVES

- Identify and document threats and vulnerabilities affecting the WatchGuard system
- Evaluate likelihood and impact levels for each identified risk
- Prioritize risks using a structured risk matrix
- Develop mitigation strategies and assign ownership for remediation
- Produce a formal Risk Assessment Plan and Risk Assessment Report following NIST SP 800-30 guidance

---

### DELIVERABLES

| File                                                 | Description                                                                                                              |
|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| NIST_SP_800-30_Risk_Assessment_Plan_WatchGuard.pdf   | Defines the scope, purpose, and methodology of the risk assessment                                                       |
| WatchGuard_Risk_Matrix_and_Register.xlsx             | Documents all identified risks, including threat sources, vulnerabilities, likelihood, impact, and mitigation strategies |
| NIST_SP_800-30_Risk_Assessment_Report_WatchGuard.pdf | Summarizes key findings, risk ratings, and recommended mitigation actions                                                |

# **NIST 800-30 Risk Assessment – WatchGuard System (Moderate Impact)**

---

## **TOOLS AND FRAMEWORKS**

- NIST SP 800-30 (Risk Assessment)
  - NIST SP 800-37 (RMF)
  - NIST SP 800-53 (Security Controls)
  - Tenable Nessus (Vulnerability Scanning)
  - Microsoft Excel (Risk Register) – Screen shot
- 

## **HOW THIS ALIGNS WITH RMF**

This project demonstrates how risk assessment (NIST 800-30) supports the Assess and Authorize steps of the Risk Management Framework (NIST 800-37). The identified risks and mitigation strategies directly inform the Security Assessment Report (SAR), Plan of Action and Milestones (POA&M), and authorization decision.

---

## **NEXT STEPS**

- Continue continuous monitoring and update the risk register with new findings.
- Perform periodic risk reassessments to validate the effectiveness of implemented controls.

# **NIST SP 800-30 RISK ASSESSMENT PLAN**

## **For WatchGuard (Moderate-Impact System)**

Winterfell Cyber Solutions

Date: June 2026

### **1. Introduction**

This document presents the Risk Assessment Plan for the WatchGuard system, a moderate-impact information system managed by Winterfell Cyber Solutions. The assessment is conducted in accordance with NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments. The goal of this plan is to provide a structured and repeatable process to identify, analyze, and prioritize risks that could affect the confidentiality, integrity, and availability of WatchGuard's information and operations.

### **2. Purpose and Scope**

The purpose of this risk assessment is to evaluate potential threats, vulnerabilities, and adverse impacts that could compromise WatchGuard's ability to operate securely. This plan covers the system's core components, including web applications, databases, authentication services, communication systems, and backup infrastructure. The assessment results will support informed risk-based decision-making, continuous monitoring, and compliance with NIST SP 800-37 and NIST SP 800-53 requirements.

### **3. System Description**

WatchGuard supports critical business operations by providing a secure platform for managing sensitive but unclassified data. The system operates in a hybrid environment that combines Azure-hosted virtual machines with on-premises network components. Users include system administrators, security analysts, and authorized employees accessing moderate-impact data through secure web interfaces. Given its categorization of Moderate (C: Moderate / I: Moderate / A: Moderate), WatchGuard requires robust controls to mitigate risks across all system layers.

### **4. Assessment Methodology**

This risk assessment follows the NIST SP 800-30 framework, which defines a four-step process: (1) Prepare for the assessment, (2) Conduct the assessment, (3) Communicate results, and (4) Maintain the assessment. During this process, the team will identify threat sources and events, determine vulnerabilities and predisposing conditions, analyze likelihood and impact, and produce a final risk determination. Results will feed directly into the organization's Risk Management Framework (RMF) and continuous monitoring strategy.

## 5. Assumptions and Constraints

This assessment assumes that system boundaries, components, and interconnections are accurately defined in the System Security Plan (SSP). The analysis is limited to assets within the defined WatchGuard authorization boundary. The assessment focuses on existing configurations, known vulnerabilities, and realistic threat sources relevant to a moderate-impact environment.

## 6. Threat and Vulnerability Identification

Threats to the WatchGuard system include unauthorized access attempts, data exfiltration, system misconfigurations, outdated software versions, and insider threats. Vulnerabilities are identified through Tenable Nessus scanning, configuration reviews, and audit log analysis. Key threat sources include external actors, malicious insiders, and accidental user actions that could lead to data loss or system downtime.

## 7. Risk Analysis Approach

Each identified risk will be analyzed based on likelihood of occurrence and potential impact on confidentiality, integrity, and availability. Risks will be assigned a qualitative rating (Low, Moderate, or High) using a standard risk matrix. This analysis enables prioritization of remediation activities and resource allocation for risk response.

## 8. Risk Determination Matrix

| Likelihood | Impact (Low) | Impact (Moderate) | Impact (High) |
|------------|--------------|-------------------|---------------|
| Low        | Low          | Low               | Moderate      |
| Moderate   | Low          | Moderate          | High          |
| High       | Moderate     | High              | High          |

## 9. Roles and Responsibilities

- System Owner: Oversees the risk assessment process and approves final results.
- Information System Security Officer (ISSO): Leads risk identification, documentation, and reporting.
- Security Analysts: Conduct vulnerability scans and analyze technical findings.
- Authorizing Official (AO): Reviews risk assessment results to support risk acceptance decisions.
- Stakeholders: Provide input on operational impacts and participate in mitigation planning.

## **10. Assessment Schedule and Maintenance**

The initial assessment will be completed during the authorization phase, followed by annual reviews or upon significant system changes. Continuous monitoring activities, such as monthly vulnerability scans and quarterly control reviews, will ensure ongoing risk visibility. All results will be documented and integrated into the organization's continuous monitoring strategy.

## **11. Conclusion**

This Risk Assessment Plan provides the structure and methodology required to evaluate risks to the WatchGuard system in alignment with NIST SP 800-30. By systematically identifying and analyzing risks, Winterfell Cyber Solutions can prioritize mitigation efforts, maintain compliance, and ensure ongoing protection of system assets and data.

| WatchGuard Risk Register                     |                                                                        |                                       |                                                            |            |          |            |                                                                                                     |                      |             |                        |
|----------------------------------------------|------------------------------------------------------------------------|---------------------------------------|------------------------------------------------------------|------------|----------|------------|-----------------------------------------------------------------------------------------------------|----------------------|-------------|------------------------|
| Project Name                                 | WatchGuard                                                             |                                       |                                                            |            |          |            |                                                                                                     | Risk Response        |             |                        |
| System Owner                                 | Catelyn Stark                                                          |                                       |                                                            |            |          |            |                                                                                                     | Avoid                |             |                        |
| Date Updated                                 | 9-Jun-26                                                               |                                       |                                                            |            |          |            |                                                                                                     | Mitigate             |             |                        |
|                                              |                                                                        |                                       |                                                            |            |          |            |                                                                                                     | Accept               |             |                        |
|                                              |                                                                        |                                       |                                                            |            |          |            |                                                                                                     | Transfer             |             |                        |
| Risk ID                                      | Risk Description                                                       | Threat Source                         | Vulnerability                                              | Likelihood | Impact   | Risk Score | Mitigation Strategy                                                                                 | Responsible Party    | Status      | RMF Control Reference  |
| R-002                                        | Misconfigured access controls allow excessive privileges.              | Malicious insider                     | Weak role-based access control enforcement.                | High       | High     | High       | Review and update RBAC policies, enforce least privilege, and audit user permissions quarterly.     | ISSO                 | In Progress | AC-6, AC-2, AC-3, AC-5 |
| R-005                                        | Data backup configuration does not include offsite storage.            | Natural disaster or ransomware attack | Single-point-of-failure in backup strategy.                | Low        | High     | Moderate   | Implement secure offsite and cloud-based backups with encryption.                                   | System Owner         | Planned     | CP-06, CP-09, CP-10    |
| R-004                                        | Lack of network segmentation between production and test environments. | External attacker or insider          | Flat network architecture increases lateral movement risk. | Low        | High     | Moderate   | Implement VLAN segmentation and firewall rules to separate environments.                            | Network Engineer     | Planned     | SC-7, SC-7(3)          |
| R-001                                        | Outdated TLS protocol (TLS 1.0) in use on application servers.         | External attacker                     | Use of deprecated cryptographic protocols.                 | Moderate   | Moderate | Moderate   | Disable TLS 1.0 and enforce TLS 1.2 or higher. Validate cipher configurations across all endpoints. | System Administrator | Open        | SC-13, SC-8            |
| R-003                                        | Unpatched vulnerabilities on Azure-hosted VMs.                         | External attacker                     | Delayed patch management cycle.                            | Moderate   | Moderate | Moderate   | Implement automated patching schedule and perform monthly vulnerability scans with Nessus.          | Security Analyst     | Open        | SI-2, RA-5, CM-3, CM-6 |
| Key Take aways                               |                                                                        |                                       |                                                            |            |          |            |                                                                                                     |                      |             |                        |
| High-priority risks require quarterly review |                                                                        |                                       |                                                            |            |          |            |                                                                                                     |                      |             |                        |
|                                              |                                                                        |                                       |                                                            |            |          |            |                                                                                                     |                      |             |                        |
|                                              |                                                                        |                                       |                                                            |            |          |            |                                                                                                     |                      |             |                        |

# NIST SP 800-30 RISK ASSESSMENT REPORT

## For WatchGuard (Moderate-Impact System)

Winterfell Cyber Solutions

Date: June 2026

### 1. Executive Summary

This report presents the results of the risk assessment conducted for the WatchGuard system, a moderate-impact information system operated by Winterfell Cyber Solutions. The assessment follows NIST SP 800-30 Revision 1 and identifies key threats, vulnerabilities, and risks impacting the confidentiality, integrity, and availability of WatchGuard. Overall, WatchGuard maintains a strong security posture; however, several medium and high-risk items were identified that require remediation to strengthen compliance and operational resilience.

### 2. Key Risks Identified

- R-001 – Outdated TLS protocol (TLS 1.0) in use on servers increases exposure to cryptographic exploits.
- R-002 – Misconfigured access controls allow excessive privileges and risk of insider misuse.
- R-003 – Unpatched Azure virtual machines introduce vulnerability to known exploits.
- R-004 – Lack of network segmentation increases risk of lateral movement during an attack.
- R-005 – Backup configuration does not include secure offsite storage, raising recovery concerns.

### 3. Risk Summary Table

| Risk ID | Likelihood | Impact   | Risk Score | Status      |
|---------|------------|----------|------------|-------------|
| R-001   | Moderate   | Moderate | Moderate   | Open        |
| R-002   | High       | High     | High       | In-progress |
| R-003   | Moderate   | Moderate | Moderate   | Open        |
| R-004   | Low        | High     | Moderate   | Planned     |
| R-005   | Low        | High     | Moderate   | Planned     |

### 4. Recommendations

The following actions are recommended to reduce overall risk exposure and strengthen

WatchGuard's security posture:

- Disable TLS 1.0 and enforce TLS 1.2 or higher across all communication endpoints.
- Implement regular access control reviews and enforce least privilege principles.
- Establish automated patch deployment for Azure-hosted systems and integrate Nessus scan results.
- Create segmented VLANs and firewall policies to isolate production and testing environments.
- Establish encrypted, offsite, and cloud-based backup storage to support disaster recovery.

## **5. Residual Risk and Conclusion**

Upon implementation of the above recommendations, residual risk is expected to fall within Winterfell Cyber Solutions' acceptable tolerance level for moderate-impact systems. The assessment confirms that WatchGuard's controls, when combined with continuous monitoring and periodic reviews, provide an effective foundation for managing cybersecurity risks. It is recommended that risk assessments be revisited annually or upon significant system changes to ensure emerging threats are promptly addressed